Diagnóstico del arnés

Resumen ejecutivo. La suite original falla 4 de 4 pruebas (E1). La ruta estática bloqueó las 3 de interfaz: el servidor resuelve la carpeta con `URL.pathname` y, como la ruta del proyecto tiene un espacio, `GET /` responde `Cannot GET /`. La de API también fallaba por su cuenta: consulta la operación con ID fijo 1, que no existe en una base limpia (E4). Corregida la ruta, aparecen las fallas de la suite y un pipeline que **nunca puede fallar**. Hay dos defectos de negocio abiertos: DEF-01 y DEF-02.

Prior.	Hallazgo	Tipo	Impacto	Acción	Evid.
P1	`express.static(new URL(...).pathname)` falla con espacios en la ruta: `GET /` da 404.	Funcional	Bloquea la interfaz y las 3 pruebas de UI.	**Corregido** con `fileURLToPath`.	E1 E2 E3
P1	El pipeline nunca falla: `continue-on-error`, script inexistente, Node 16, `npm start &` sin espera, k6 ausente y `|| true`.	CI	Falsos verdes sin reporte.	**Corregido** en `quality.yml`.	E5 E6
P1	Token `qa-token-2026-visible` en el YAML.	Seguridad	Secreto expuesto.	**Corregido**: `secrets.RISK_API_TOKEN`; rotarlo.	E7
P1	DEF-02, doble gasto: el saldo se valida antes del `await` al servicio de riesgo. Saldo $ 100 y cinco operaciones simultáneas de $ 90: todas aprobadas, saldo -$ 395.	Funcional	Pérdida financiera.	**Abierto**: fallo esperado solo si se reproduce. Requiere bloqueo o transacción.	E8 E9 E10
P2	DEF-01: se valida el monto, pero se descuenta monto + 10 %. Saldo $ 1.000 y operación de $ 1.000: saldo -$ 100.	Funcional	Saldos negativos.	**Abierto**: fallo esperado solo si se reproduce. El cargo se conserva.	E8 E10
P2	El resumen muestra `PENDING` fijo.	Funcional (UI)	Estado falso en pantalla.	**Corregido**.	E11
P2	Pruebas acopladas por orden e ID fijo (cliente 2, operación 1), documento quemado y saldo esperado sin el cargo.	Automatización	Fallas según orden o workers.	**Corregido**: pruebas independientes, datos sintéticos.	E4
P2	`RISK_MODE=random` rechaza el 15 % sin control.	Automatización	Inestabilidad.	**Corregido**: proyectos `approved` y `rejected`.	E12
P3	`waitForTimeout` fijos ante un refresco aleatorio de 300 a 1500 ms.	Automatización	Inestabilidad y lentitud.	**Corregido**: esperas por condición.	E4
P3	Pruebas sobre la base de desarrollo; `reuseExistingServer` usó un servidor viejo.	Automatización	Datos y resultados falsos.	**Corregido**: base aislada y teardown.	E13
P3	La API acepta saldo negativo o no numérico y correo sin formato; `app.js` inserta el nombre con `innerHTML` (XSS).	Funcional / Seguridad	Datos corruptos y script ajeno.	**Pendiente** en API y `app.js`; la capa pública muestra los datos como texto.	E8 E14
P4	Persistencia JSON completa e IDs `max+1`; el mock de riesgo ignora el token.	Arquitectura	No escala con concurrencia.	Riesgo aceptado para el laboratorio.	E15
P4	Trazas, video y captura siempre activos.	Automatización	Costo y ruido.	**Corregido**: en GitHub Actions, solo en fallos.	E16

Evidencias (en `evidencias/`, salvo E12 y E15). E1 `baseline/suite-original-corrida-1.txt` · E2 `baseline/probe-static.txt` · E3 `baseline/cannot-get-root.png` · E4 `baseline/suite-original-tras-fix-static.txt` · E5 `pipeline/actionlint-original.txt` · E6 `pipeline/actionlint-corregido.txt` · E7 `publicacion/escaneo-secretos.txt` · E8 `baseline/sondeo-defectos-api.txt` · E9 `e2e/estabilidad-repeat-each-5-19.txt` · E10 `e2e/defectos-falla-controlada.txt` · E11 `e2e/mutacion-pending-detectada.txt` · E12 `tests/support/environments.js` · E13 `baseline/suite-original-reutilizo-servidor-viejo.txt` · E14 `e2e/resumen-texto-seguro-mutacion.txt` · E15 `src/db.js` · E16 `pipeline/adjuntos-por-origen.txt`

Dependencias. Node 20+ con lockfile, Express 4, Playwright con Chromium y k6. La app se llama a sí misma como servicio de riesgo (`RISK_SERVICE_URL`). Puertos 4310 y 4311 (E2E) y 3000 (k6 en CI). En GitHub, el secreto `RISK_API_TOKEN`.

Orden de corrección aplicado. (1) Desbloquear la app. (2) Hacer que el pipeline pueda fallar. (3) Aislar datos y ambiente. (4) Reescribir las pruebas. (5) Rendimiento. Siguiente para desarrollo: DEF-01 y DEF-02 antes de salir a producción.